Procédure Gestion des incidents de sécurité

Domaine :	Sécurité des systèmes d'information
Macro Processus :	Opérations de sécurité
Processus :	Gestion des incidents de sécurité
Référence :	SEC-03
Version :	2.3

Responsables du document

	Nom	Entité	Date
Rédacteur(s)	Sofia Mekouar (Consultante Organisation)	DTPO	13/02/2026
Vérificateur(s)	Reda Cherkaoui (Responsable des Opérations de Sécurité)	DSSI	05/03/2026
	Ilham Tazi (Responsable de la Sécurité des Systèmes d'Information (RSSI))	DSSI	05/03/2026
	Salma El Fassi (Responsable Exploitation et Support)	DSI	05/03/2026
	Kenza Hajji (Responsable Conformité)	CONF	05/03/2026
	Jalil Benkirane (Responsable Risques Opérationnels)	DR	05/03/2026
Approbateur(s)	Ilham Tazi (Responsable de la Sécurité des Systèmes d'Information (RSSI))	DSSI	20/03/2026
	Kenza Hajji (Responsable Conformité)	CONF	20/03/2026
	Najat Belkadi (Directrice Transformation, Processus et Organisation)	DTPO	20/03/2026

Propriétaire de la procédure : Reda Cherkaoui (Responsable des Opérations de Sécurité).

Historique des révisions

Emetteur	Description	Demande de révision	Version	Approbation
Sofia Mekouar	Création de la procédure		1.0	09/01/2023
Sofia Mekouar	Mise en place du SOC (projet PRJ-SOC-2025)	DR-2025-20	2.0	03/11/2025
Sofia Mekouar	Ajout de la notification aux autorités	DR-2026-27	2.3	30/03/2026

Généralités

Objet

Cette procédure définit la détection, la qualification, le traitement et la clôture des incidents de sécurité des systèmes d'information d'Orizia. Elle fixe les délais de réaction et les obligations de notification.

Domaine d'application

Entrent dans le périmètre

- Intrusions, logiciels malveillants, fuites de données, hameçonnage et usages frauduleux
- Événements détectés par OriSOC ou signalés par les collaborateurs

Sont exclus du périmètre

- Incidents de disponibilité sans suspicion de malveillance, traités selon IT-01

Références

- Politique de sécurité des systèmes d'information d'Orizia
- Procédure IT-07
- Procédure amont IT-01 – Gestion des incidents informatiques : Les incidents informatiques suspects sont transmis au SOC.
- Procédure aval IT-07 – Plan de continuité et de reprise d'activité informatique : Un incident majeur peut conduire à l'activation du plan de reprise.
- Procédure amont SEC-02 – Gestion des comptes à privilèges : Les usages anormaux de comptes à privilèges sont des incidents de sécurité.
- Procédure complémentaire SEC-04 – Gestion des vulnérabilités et des correctifs de sécurité : Les vulnérabilités exploitées alimentent l'analyse de l'incident.
- Procédure complémentaire SEC-06 – Évaluation de la sécurité des fournisseurs et prestataires : Les clauses contractuelles de sécurité sont activées en cas d'incident impliquant un fournisseur.
- Projet : PRJ-SOC-2025 – Mise en place du centre des opérations de sécurité (OriSOC).

Définitions

- OriSOC : Plateforme de supervision et de détection des événements de sécurité.
- OriDesk : Outil de gestion des services informatiques (incidents, demandes, changements).
- RSSI : Responsable de la Sécurité des Systèmes d'Information.

Acteurs

Acteur	Direction / Entité	Rôle dans la procédure
Collaborateur	Toutes directions	Signale tout événement suspect
Analyste SOC	DSSI	Analyse les alertes et qualifie les événements
Responsable des Opérations de Sécurité	DSSI	Pilote le traitement des incidents de sécurité
Responsable de la Sécurité des Systèmes d'Information	DSSI	Décide de la criticité et des notifications
Responsable Conformité	CONF	Évalue les obligations de notification aux autorités
Directeur des Systèmes d'Information	DSI	Décide, avec le RSSI, de l'activation du plan de reprise

Sommaire

Responsables du document
Historique des révisions
Généralités
Objet
Domaine d'application
Références
Définitions
Acteurs
Règles de gestion
Liste des contrôles
Logigramme
Commentaires du logigramme
Opérations
Annexes

Règles de gestion

I- Pré-requis

La réalisation de la procédure nécessite la disponibilité des éléments suivants :

- OriSOC opérationnel avec les sources de journaux connectées
- Annuaire de crise à jour

II- Règles applicables

R1. Un incident S1 correspond à une compromission avérée ou à une fuite de données clients. Il est traité immédiatement et escaladé au RSSI sous 30 minutes.

R2. Un incident S2 correspond à une compromission limitée sans donnée client. Il est traité sous 4 heures.

R3. Un incident S3 correspond à une tentative bloquée ou à un événement sans impact. Il est traité sous 2 jours ouvrés.

R4. Tout incident S1 est communiqué à la Direction Générale dans les 2 heures.

R5. La notification aux autorités, lorsqu'elle est requise, est décidée par le Responsable Conformité avec le RSSI.

R6. Un incident S1 peut conduire à l'activation du plan de reprise d'activité selon la procédure IT-07.

R7. Les preuves numériques sont préservées et leur chaîne de conservation est documentée.

III- Exceptions et cas particuliers

- Hors heures ouvrées, l'astreinte du SOC prend en charge les incidents S1 et S2.
- Lorsque l'incident implique un fournisseur, le Responsable Achats est informé afin d'activer les clauses contractuelles de sécurité (SEC-06).

IV- Sorties et archivage

- Sortie : Dossier d'incident clôturé dans OriSOC
- Sortie : Compte rendu de retour d'expérience
- Les dossiers d'incident sont conservés 10 ans.

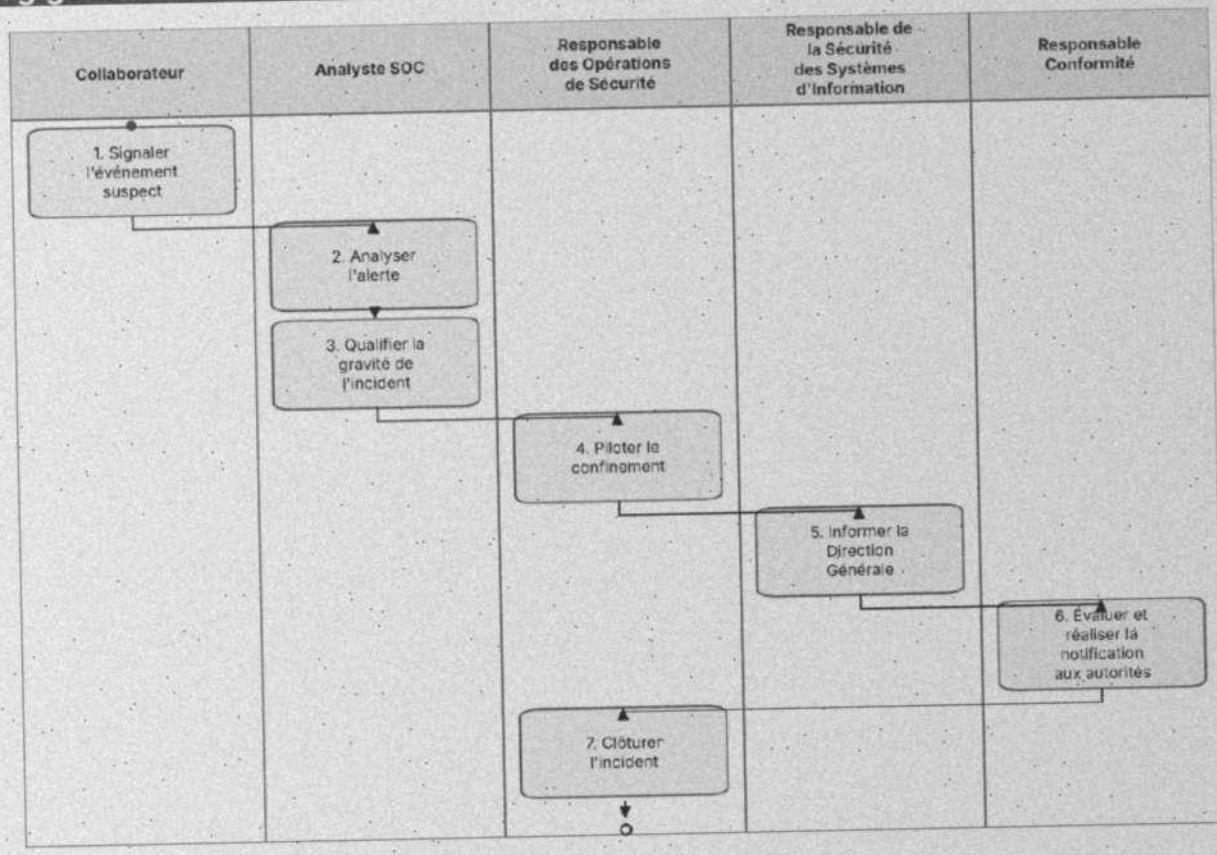
V- Indicateurs de suivi

Indicateur	Cible
Délai moyen de qualification des alertes	1 heure maximum
Taux d'incidents S1 escaladés dans les 30 minutes	100 %
Taux de retours d'expérience réalisés	100 % des incidents S1 et S2

Liste des contrôles

N°	Contrôle	Responsable du contrôle	Fréquence
C1	Revue mensuelle des incidents de sécurité et du respect des délais	Responsable de la Sécurité des Systèmes d'Information	Mensuelle
C2	Exercice de simulation d'incident de sécurité	Responsable des Opérations de Sécurité	Annuelle
C3	Contrôle de la complétude des dossiers d'incident S1	Contrôle Permanent	Semestrielle

Logigramme



Commentaires du logigramme

Opérations

Temporisateur : Dès la détection

Libellé de l'opération	Acteur
1. Signaler l'événement suspect	**Collaborateur**

Commentaires :

Signale l'événement suspect au Service Desk ou à l'adresse dédiée.

Outil(s) : OriDesk. Délai : Dès la détection.

Libellé de l'opération	Acteur
2. Analyser l'alerte	**Analyste SOC**

Commentaires :

Analyse l'alerte, écarte les faux positifs et ouvre un dossier d'incident.

Outil(s) : OriSOC. Délai : 30 minutes.

Libellé de l'opération	Acteur
3. Qualifier la gravité de l'incident	**Analyste SOC**
Commentaires : Qualifie la gravité de l'incident (niveaux S1 à S3). *Outil(s) : OriSOC. Délai : 1 heure.*	

Libellé de l'opération	Acteur
4. Piloter le confinement	**Responsable des Opérations de Sécurité**
Commentaires : Pilote le confinement, l'éradication et la remise en état. *Outil(s) : OriSOC. Délai : Selon gravité.*	

Libellé de l'opération	Acteur
5. Informer la Direction Générale	**Responsable de la Sécurité des Systèmes d'Information**
Commentaires : Informe la Direction Générale et la Conformité pour tout incident S1. *Outil(s) : OriDesk. Délai : 2 heures.*	

Libellé de l'opération	Acteur
6. Évaluer et réaliser la notification aux autorités	**Responsable Conformité**
Commentaires : Évalue et réalise la notification aux autorités lorsqu'elle est requise. *Outil(s) : OriDesk. Délai : Dans les délais réglementaires.*	

Libellé de l'opération	Acteur
7. Clôturer l'incident	**Responsable des Opérations de Sécurité**
Commentaires : Clôture l'incident et organise le retour d'expérience. *Outil(s) : OriSOC. Délai : 10 jours ouvrés.*	

Annexes

Sans objet.